

Angebot zur

Augsburg Maschinenbau GmbH

Fakultät für
Elektrotechnik

Einführung eines Informationssicherheits- Managementsystems (ISMS)

Beratungskonzept für ISMS

Verfasser der
Angebot:

Vaisakh Narayanan Nair
M.Sc. Industrielle Sicherheit
an der Hochschule 1
86161 Augsburg
E: vaisakh.narayanan.nair1@tha.de

Matrikel-Nr.:
2289674

erstellt von
Vaisakh Narayanan Nair (M.Eng.)
Technische Hochschule Augsburg

Version: 1.0 (Vertraulich)
Datum: 12.06.2026
Ort: Augsburg, Bayern

Management Summary

Die Maschinenbau Augsburg GmbH steht an einem kritischen Wendepunkt: Zunehmende Digitalisierung der Fertigung, vernetzte Produktionssysteme und externe Dienstleisterzugriffe schaffen eine Angriffsfläche, die mit fragmentierten Einzelmaßnahmen nicht mehr beherrschbar ist. Gleichzeitig belegt die regionale Schadenslage: von den Wertachkliniken Bobingen/Schwabmünchen (Sept. 2024) über die Brockhaus Fertigungstechnik GmbH (Januar 2026) bis zu einem namentlich nicht genannten Fertigungsunternehmen in Bayerisch-Schwaben (Juni 2025), dass Produktionsunternehmen in der Region unmittelbar gefährdet sind.

Der Gesamtschaden durch Cyberkriminalität in Deutschland beläuft sich 2025 auf 202 Milliarden Euro [1]. Ransomware-Angriffe verursachen im Durchschnitt einen Produktionsstillstand von 21 Tagen [2]. Die Fertigungsindustrie ist mit einem Anteil von 27,7 % aller globalen Cyberangriffe das meistangegriffene Segment [3]. Für bayerische Unternehmen gilt: Mindestens 20 % der Betriebe waren bereits Opfer eines erheblichen Cybervorfalles [4].

Dieses Beratungskonzept entwickelt für die Maschinenbau Augsburg GmbH (210 Mitarbeitende) einen realistischen, akzeptanzorientierten Weg vom aktuellen Ad-hoc-Niveau (Stufe 1) auf ein strukturiertes, gemanagtes ISMS-Niveau (Stufe 3) gemäß dem ISMS-Reifegradmodell nach ISO/IEC 27001:2022 [5] innerhalb von 24 Monaten, mit einem Gesamtbudget von 80.000–150.000 €.

Das Konzept adressiert drei gleichrangige Handlungsebenen: Governance & Struktur, technische Maßnahmen und Mensch & Kultur. Der entscheidende Unterschied zu klassischen IT-Projekten: Change-Management, Führungspsychologie und partizipative Regelentwicklung stehen gleichberechtigt neben technischen Maßnahmen – denn Technologie allein schützt kein Unternehmen, das Sicherheit als Produktivitätshemmnis begreift.

„Cybersicherheit ist keine IT-Frage, sie ist eine Überlebensfrage für den Mittelstand.“

Bitkom e.V., 2025

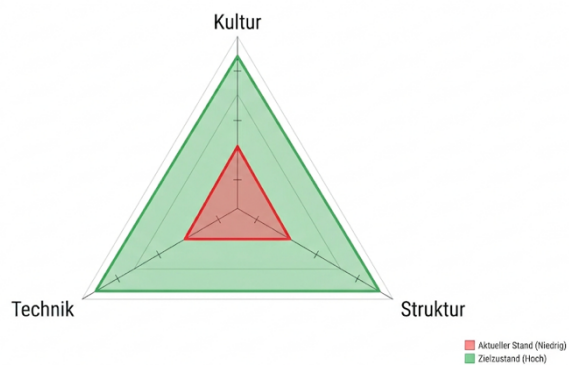
1. Analyse & Zielbild

1.1 Interpretation der Ausgangssituation

Die Maschinenbau Augsburg GmbH verfügt über punktuelle Sicherheitsmaßnahmen (Antivirus, Firewall, Passwortrichtlinien, unregelmäßige Datensicherungen), jedoch über kein systematisches Informationssicherheitsmanagement. Die Lage ist durch drei Dimensionen der Verwundbarkeit gekennzeichnet:

Kulturelle Dissonanz: Sicherheitsmaßnahmen werden auf dem Shopfloor aktiv umgangen. Führungskräfte priorisieren Output. Dieses Muster entspricht dem psychologischen Phänomen der Reaktanz [6]: Werden Sicherheitsregeln als externe Kontrolle erlebt, die die Handlungsfreiheit einschränkt, entsteht motivationaler Widerstand: selbst bei rationaler Akzeptanz des Risikos. Ohne gezielte Change-Management-Interventionen ist eine technische Lösung allein wirkungslos.

Strukturelle Defizite: Eine 3-köpfige IT-Abteilung im operativen Dauerstress kann kein ISMS aufbauen und gleichzeitig den laufenden Betrieb sicherstellen. Es fehlt ein Informationssicherheitsbeauftragter (ISB), eine dokumentierte Risikoanalyse und eine ISMS-Leitlinie mit Mandat der Geschäftsführung – allesamt Mindestanforderungen der ISO/IEC 27001:2022 [5] und des NIS2-Umsetzungsgesetzes (BSIG §30).



Technische Schwächen: Die fehlende Segmentierung zwischen IT- und OT-Netz ist das kritischste Einzelrisiko. Eine kompromittierte Büro-Workstation kann ohne Firewall-Barriere direkt Produktionssysteme erreichen – ein Angriffspfad, den Ransomware-Akteure systematisch ausnutzen [3]. Nicht getestete Backups sind im Schadensfall wertlos, wie der Angriff auf das Fertigungsunternehmen in Bayerisch-Schwaben (Juni 2025) mit gezielter Backup-Löschung belegt.

1.2 Hauptursachen der Sicherheitsrisiken

Nu.	Ursache	Kategorie	Priorität
1	Fehlende IT/OT-Netzsegmentierung	Technik	Kritisch
2	Keine ISMS-Governance/ kein ISB	Struktur	Kritisch
3	Remote-Zugänge ohne MFA/PAM	Technik	Kritisch
4	Backups nie auf Wiederherstellbarkeit getestet.	Technik	Kritisch
5	Sicherheit = Produktivitätshemmnis (Kulturwahrnehmung)	Kultur	Hoch
6	Keine systematische Risikoanalyse	Struktur	Hoch
7	Kein Incident-Response-Plan	Struktur	Hoch
8	Dienstleisterrisiken (SupplyChain) nicht adressiert	Struktur	Mittel
9	Kein Security-Awareness-Programm	Kultur	Mittel

1.3 Bewertung vorhandener Maßnahmen

Ausbaufähige Grundlage (sinnvoll, aber unzureichend):

- Antivirus & Firewall: Basishygiene vorhanden, jedoch ohne zentrale Verwaltung und ohne OT-Coverage
- IT-Abteilung: Fachkompetenz vorhanden, aber strukturell überlastet und ohne ISMS-Mandat
- Passwortrichtlinien: Existieren punktuell, jedoch nicht technisch erzwungen (kein Active Directory Enforcement dokumentiert)
- Datensicherungen: Vorhanden, jedoch ohne dokumentierten Recovery-Test im Ernstfall faktisch wertlos

Nicht sinnvoll (Scheinsicherheit):

- Backups als Sicherheitsmerkmal zu kommunizieren, solange deren Wiederherstellbarkeit nie validiert wurde, erzeugt ein gefährliches Sicherheitsgefühl [5]

1.4 Blinde Flecken und nicht adressierte Risiken

Folgende Risiken existieren heute ohne jede Gegenwehr:

- OT-spezifische Schwachstellen: Ältere Produktionssysteme (Legacy-PLCs, SCADA) erhalten oft keine Sicherheits-Patches, IEC 62443 [7] adressiert diese Umgebungen explizit, ist im Unternehmen bislang unbekannt
- Supply-Chain-Risiken: Dienstleisterzugänge sind weder inventarisiert noch mit zeitlich begrenzten Zugriffsrechten versehen – ein typischer Einfallsvektor, wie der Pilz GmbH-Vorfall (Oktober 2021) zeigte
- Social Engineering / Phishing: Die aktuelle Klickrate bei ungezielten Phishing-Simulationen liegt bei KMUs branchenweit bei ca. 25 % [2]; kein Awareness-Programm adressiert dies.
- Kein Incident-Response-Plan (IRP): Im Angriffsfall fehlt ein dokumentierter Prozess, Reaktion erfolgt improvisiert, was die Mean Time to Recovery (MTTR) erheblich verlängert [8]

1.5 Entwicklungspfad: von Reaktiv zu Systematisch

Das Reifegradmodell nach ISO/IEC 27001:2022 [5] beschreibt fünf Stufen. Die Maschinenbau Augsburg GmbH befindet sich auf **Stufe 1 (Ad-hoc)**: Sicherheitsmaßnahmen sind unkoordiniert, nicht dokumentiert und personenabhängig. Das Ziel nach 24 Monaten ist **Stufe 3 (Defined/Managed)**: Prozesse sind definiert, dokumentiert, rollenbasiert und messbar.



Der Entwicklungspfad verläuft nicht sequenziell, sondern parallel auf allen drei Handlungsebenen – Governance, Technik und Kultur müssen synchronisiert beginnen, da gegenseitige Abhängigkeiten bestehen: Eine Risikoanalyse ohne ISB ist führungslos; technische Maßnahmen ohne kulturelle Vorbereitung erzeugen Reaktanz [6]; Kulturwandel ohne sichtbares Führungsmandat bleibt wirkungslos [9].

2. Maßnahmenvorschlägen

2.1 Handlungsebene 1: Governance & Struktur

Maßnahme G-1: Benennung eines Informationssicherheitsbeauftragten (ISB) (Monat 1)

Der ISB ist die zentrale Voraussetzung für alle weiteren Maßnahmen. Ohne eine benannte, mit Mandat ausgestattete Person bleibt das ISMS ein Projekt ohne Eigentümer. Die rechtliche Verpflichtung ergibt sich aus NIS2 Art. 20 und BSIG §30 für Betreiber wesentlicher oder wichtiger Einrichtungen.

Konkrete Ausgestaltung: In Phase 1 wird der ISB extern besetzt (50 % Kapazität), um sofortige Handlungsfähigkeit zu gewährleisten. Parallel wird intern ein Kandidat identifiziert und aufgebaut – Übergang zu internem ISB spätestens in Monat 18. Der ISB erhält direktes Berichtsrecht an die Geschäftsführung und nimmt monatlich am GF-Meeting teil.

Maßnahme G-2: ISMS-Leitlinie mit GF-Unterschrift (Monat 2)

Die Geschäftsführung unterzeichnet eine öffentlich kommunizierte ISMS-Leitlinie. Dies ist kein bürokratischer Formalismus: Die Forschung zum Führungsengagement in der Informationssicherheit zeigt, dass sichtbares Führungsengagement die Mitarbeitercompliance um bis zu **30 % erhöht** [10]. Die Leitlinie setzt den „Tone from the Top“ gemäß ISO/IEC 27001:2022 Kapitel 5 [5] und signalisiert der gesamten Belegschaft, dass Sicherheit Chefsache ist.

Konkrete Ausgestaltung: Die Leitlinie wird im Umfang von 1 bis 2 Seiten gehalten (keine 30-seitigen Dokumente, die niemand liest), in der Schichtbesprechung vorgestellt und am Schwarzen Brett in der Produktion ausgehängt.

Maßnahme G-3: Strukturierte Risikoanalyse nach ISO/IEC 27005 (Monat 2–3)

Die Risikoanalyse bildet die sachliche Grundlage für alle Priorisierungsentscheidungen. Ohne sie ist jede Maßnahme eine Vermutung.

Konkrete Ausgestaltung: 3-tägiger Workshop mit ISB, IT-Abteilung und je einem Vertreter der Produktion. Methode: Asset-Inventarisierung → Bedrohungsidentifikation (STRIDE-Methodik [11]) → Risikobeurteilung → Maßnahmenplanung. Ergebnis: Priorisierte Risikoliste als Steuerungsinstrument für das gesamte ISMS.

Rolle der Geschäftsführung: Die Geschäftsführung ist kein passiver Auftraggeber, sondern aktiver ISMS-Treiber. Konkrete Erwartungen:

Aktivität	Frequenz	Wirkung
ISMS-Leitlinie öffentlich unterzeichnen	Einmalig (Monat 2)	Signalwirkung Tone from the Top [5]
ISMS als fester Agenda-Punkt im GF-Meeting	Monatlich	Institutionalisierung, Prioritätssignal
Teilnahme an Tabletop-Übung (simulierter Cyberangriff)	Mindestens 1× pro Jahr	Vorbildfunktion, eigene Kompetenz
Besuch im OT-Bereich mit Sicherheitsthema	Quartalsweise	Shopfloor-Vertrauen aufbauen

2.2 Handlungsebene 2: Technische Maßnahmen

Maßnahme T-1: IT/OT-Netzwerksegmentierung (Kritisch: Monat 1–2)

Die Vermischung von Büronetz und Produktionsnetz ist das gefährlichste Einzelrisiko. Eine VLAN-Trennung mit strikten Firewall-Regeln zwischen IT und OT begrenzt den Explosionsradius eines Angriffs auf ein Netzsegment.

Konkrete Ausgestaltung:

- VLAN-Konfiguration: Produktionsnetz (OT-VLAN), Büronetz (IT-VLAN), DMZ für Dienstleisterzugriffe
- Firewall-Regelwerk: Whitelist-Prinzip (nur explizit erlaubter Traffic passiert)
- Überwachung: Logging aller Grenzübergänge zwischen VLANs

Normative Grundlage: IEC 62443-3-3 SR 5.1 [7], ISO/IEC 27001:2022 Annex A.8.22 [5], BSI-Grundschrift NET.1.1

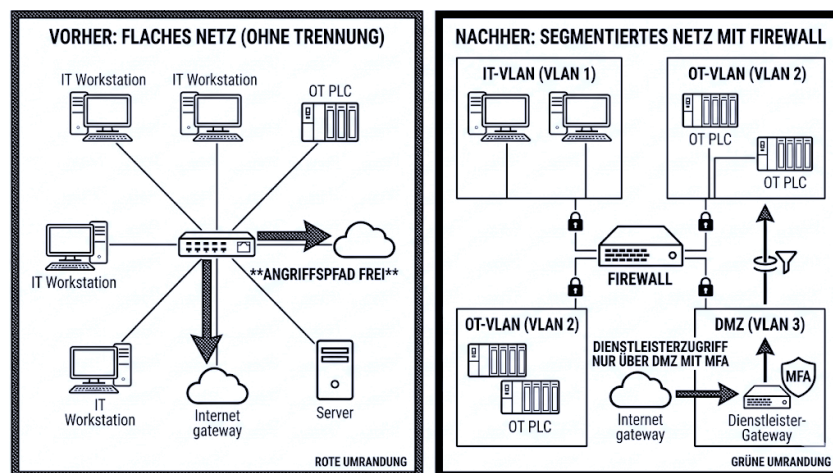


Figure 1: IT/OT Segmentierung - Vorher/Nachher (Generiert mit Gemini Pro 3 Preview)

Maßnahme T-2: Multi-Faktor-Authentifizierung für alle Remote-Zugänge (Kritisch: Monat 1–3)

Unsichere Remote-Zugänge sind einer der häufigsten initialen Angriffsvektoren. Das Zero-Trust-Prinzip – kein Zugang ohne explizite Verifikation, unabhängig vom Netzwerkstandort – muss für alle externen Zugänge gelten [3].

Konkrete Ausgestaltung für die Produktionsumgebung (Security-by-Design):

- Büromitarbeitende und Dienstleister: Software-Token (Authenticator-App) oder Hardware-Token
- Produktionsmitarbeitende: RFID-Badge als zweiter Faktor statt Passwort – keine Passwortmerkpflcht, kein Produktivitätsverlust, hohe Akzeptanz auf dem Shopfloor
- Zeitlich begrenzte Dienstleisterzugänge: Zugang wird bei Beauftragung aktiviert, automatisch nach definierter Frist deaktiviert

Normative Grundlage: ISO/IEC 27001:2022 Annex A.8.5 [5], IEC 62443-3-3 SR 1.1 [7]

Maßnahme T-3: Backup-Recovery-Test (Kritisch: Woche 4, dann quartalsweise)

Ein Backup, dessen Wiederherstellbarkeit nie getestet wurde, ist im Ernstfall kein Backup. Der Angriff auf das Fertigungsunternehmen in Bayerisch-Schwaben (Juni 2025) zeigt, dass Ransomware-Akteure gezielt Backups verschlüsseln oder löschen.

Konkrete Ausgestaltung:

- Einmaliger sofortiger Test der gesamten Backup-Infrastruktur (Monat 1, Woche 4): Kann ein vollständiges System aus dem Backup in einem Testsystem wiederhergestellt werden?

- 3-2-1-Backup-Regel: 3 Kopien, 2 verschiedene Medien, 1 Kopie offline/air-gapped
- Quartalsweiser dokumentierter Recovery-Test mit Messung der Recovery Time Objective (RTO)

Normative Grundlage: ISO/IEC 27001:2022 Annex A.8.13 [5], NIS2 Art. 21(2)(c)

Maßnahme T-4: Privileged Access Management (PAM) (Monat 6–12)

Dienstleister benötigen oft weitreichende Systemzugänge. Ohne granulare Kontrolle sind diese Zugänge ein permanentes Risiko.

Konkrete Ausgestaltung:

- Inventarisierung aller Dienstleisterzugänge (Monat 6)
- Einführung einer PAM-Lösung: Zugänge werden sitzungsbasiert vergeben, protokolliert und zeitlich begrenzt
- Für jeden Dienstleister: minimale Rechtevergabe (Least-Privilege-Prinzip)

Normative Grundlage: ISO/IEC 27001:2022 Annex A.8.18 [5]

Maßnahme T-5: Incident-Response-Plan (IRP) (Monat 9–12)

Im Angriffsfall entscheiden die ersten Stunden über den Gesamtschaden. Ohne definierten IRP reagieren Teams improvisiert – was die MTTR verlängert und Fehler erzeugt [8].

Konkrete Ausgestaltung:

- Rollen und Verantwortlichkeiten im Incident: Wer entscheidet Abschaltung der Produktion? Wer informiert Kunden? Wer kontaktiert BSI/Polizei?
- Eskalationspfade: IT → ISB → GF → externe Forensik
- Recovery-Ziel: Kritische Systeme < 72 Stunden wiederhergestellt (NIS2 Art. 23 Meldepflicht)
- Jährliche Tabletop-Übung mit GF-Beteiligung

Normative Grundlage: ISO/IEC 27035 [8], NIS2 Art. 23

2.3 Handlungsebene 3: Mensch & Kultur

Maßnahme M-1: Multiplikatoren-Konzept (Sicherheits-Champions)

Top-Down-Dekrete in der Produktion erzeugen Reaktanz [6]. Ein wirksamerer Ansatz nutzt das **Prinzip der sozialen Bewährtheit** [12]: Wenn Kolleginnen aus dem eigenen Bereich Sicherheitsverhalten vorleben und erklären, ist die Übernahme wahrscheinlicher als bei Anweisungen der IT-Abteilung.

Konkrete Ausgestaltung:

- Pro Schicht / Produktionsbereich: 1 freiwilliger Sicherheits-Champion
- Auswahl: Freiwilligkeit, nicht Ernennung von oben
- Schulung: 4-stündiges Training durch ISB (kein IT-Kurs, sondern praxisnahes Sicherheitshandeln im Alltag)
- Aufgaben: Ansprechpartner für Meldungen, Teilnahme an Quartals-Reviews, Feedback-Kanal zwischen Shopfloor und ISB
- Sichtbarkeit: Namentliche Nennung am Schwarzen Brett, Aufwandsentschädigung (symbolisch: Zeitgutschrift oder kleine Prämie)

Maßnahme M-2: Fehlerkultur & Just Culture

Die Bereitschaft, Sicherheitsvorfälle zu melden, hängt direkt von der Straffreiheit ab. Reason's Konzept der **Just Culture** [13] unterscheidet systematisch zwischen menschlichen Fehlern (nicht bestrafungswürdig, zu analysieren) und vorsätzlichen Regelverstößen

(Konsequenzen notwendig). Ohne diesen Rahmen melden Mitarbeitende nichts – und Vorfälle eskalieren unbemerkt.

Konkrete Ausgestaltung:

- Einführung eines ****anonymen Meldesystems**** (niedrigschwellig: QR-Code in der Produktion → Webformular)
- Kommunikation: „Fehler passieren – wer meldet, schützt das Unternehmen und sich selbst“
- Reaktion auf Meldungen: Innerhalb von 48 Stunden Rückmeldung an Melder (anonym), was mit der Meldung geschieht
- Keine disziplinarischen Konsequenzen für versehentliche Fehler (z. B. Klick auf Phishing-Link) – stattdessen Lernintervention

Maßnahme M-3: Betriebsrat als Co-Gestalter

Der Betriebsrat verfügt über formale Mitbestimmungsrechte bei der Einführung technischer Kontrollsysteme (§87 Abs. 1 Nr. 6 BetrVG) und beim Datenschutz (§26 BDSG). Ein Betriebsrat, der ISMS-Maßnahmen als Überwachungsinstrument wahrnimmt, kann Projekte erheblich verzögern oder blockieren. Frühzeitige Einbindung wandelt dieses Risiko in eine Ressource um.

Konkrete Ausgestaltung:

- Monat 1: Informationsgespräch mit BR-Vorsitzenden: Ziele, Datenschutzfragen, Mitgestaltungsrechte.
- Monat 3: Gemeinsame Entwicklung des Entwurfs einer Betriebsvereinbarung (BV) IT-Monitoring.
- Monat 12: Abschluss der BV – klare Grenzen des Monitorings, Zweckbindung, keine Verhaltensüberwachung.
- Laufend: BR erhält quartalsweise ISMS-Statusbericht.

Kotter [9] bezeichnet dies als den entscheidenden zweiten Schritt jedes erfolgreichen Veränderungsprozesses: Aufbau einer Führungskolalition und der Betriebsrat ist ein unverzichtbarer Teil davon.

3. Umsetzungsplan & Change Management

3.1 Change-Management Rahmen

Vier komplementäre Modelle strukturieren den Veränderungsprozess:

Modell	Kernbeitrag für dieses Projekt
Lewin (1947) [14]	Unfreeze → Change → Refreeze Auftauen: Schadensdaten und regionale Vorfälle als Dringlichkeitsargument; Refreeze: Neue Normen institutionalisieren (ISB, BV, Champions)
Kotter (1996) [9]	8-Schritte-Modell Schritte 1–3 in Phase 1: Dringlichkeit aufbauen, Koalition formen (GF + BR + Champions), Vision kommunizieren.
ADKAR [15]	Awareness → Desire → Knowledge → Ability → Reinforcement Strukturiertes Modell für individuelle Veränderung: Awareness durch regionale Vorfälle, Desire durch Champions, Knowledge durch Schulungen, Reinforcement durch KPI-Feedback.
U-Theorie (Scharmer) [16]	Co-Creation: Mitarbeitende der Produktion gestalten Sicherheitsregeln mit, erhöht Identifikation und Akzeptanz nachhaltig

Grundprinzip: Sicherheitsregeln, die von Betroffenen mitentwickelt wurden, werden signifikant häufiger eingehalten als auferlegt Regeln [9]. Partizipative Regelentwicklung ist kein Nice-to-have, sondern eine Wirksamkeitsstrategie.

3.2 Kommunikationsplan

Zielgruppe	Kernbotschaft	Medium /Format	Frequenz	Verantwortlich
Geschäftsführung	ROSI, Haftungsrisiko (§43 GmbHG), NIS2-Compliance	GF-Meeting, 1-Pager	Monatlich	ISB
Führungskräfte (Schichtleiter, Bereichsleiter)	Security by Design = keine Produktivitätshemmnis	Workshop, Champion-Briefing	Monat 1, dann quartalsweise	ISB + GF
Mitarbeitende / Produktion	Melden schützt – Bestrafungsfreiheit garantiert	Schichtmeeting, Awareness-E-Learning	Quartalsweise	Sicherheits-Champion
Betriebsrat	BV IT-Monitoring (§26 BDSG), Mitgestaltungsrecht	BR-Sitzung, BV-Entwurf	3–4× Phase 1, quartalsweises Update	ISB + GF

Messbare Akzeptanzmetrik: Ziel $\geq 90\%$ Schulungsabschlussquote pro Jahr; BR-Mitgestaltung reduziert nachweislich Blockaderisiken [9].

3.3 24-Monats-Roadmap

Phase 1: Foundation (Monat 1–6) Budget: 25.000–40.000 €	Governance	• Woche 2: Erstkontakt Betriebsrat • Woche 4: Meilenstein: ISB ernannt • Monat 2: ISMS-Leitlinie unterzeichnet, Risikoanalyse gestartet • Monat 3: Risikoanalyse abgeschlossen, priorisierte Maßnahmenliste
	Technik	• Woche 4: Meilenstein: Erster Backup-Recovery-Test dokumentiert • Monat 2: Meilenstein: VLAN-Segmentierung IT/OT live • Monat 3: Meilenstein: MFA für alle Remote-Zugänge aktiv
	Mensch & Kultur	• Monat 1: GF-Workshop (Dringlichkeit, ROSI, regionale Vorfälle) • Monat 2: Führungskräfte-Workshop (Security by Design) • Monat 3: Erste Champions identifiziert und geschult • Monat 4: Anonymes Meldesystem eingeführt
Phase 2: Systematisierung (Monat 7–18) Budget: 40.000–80.000 €	Governance	• Monat 12: Meilenstein: Betriebsvereinbarung IT-Monitoring abgeschlossen
	Technik	• Monat 8: PAM für Dienstleisterzugänge eingeführt • Monat 10: OT-Sicherheitskonzept nach IEC 62443 [7] fertiggestellt • Monat 12: Patch-Management-Prozess etabliert (≥ 95 % Compliance innerhalb 30 Tage) • Monat 14: Meilenstein: Incident-Response-Plan verabschiedet, erste Tabletop-Übung durchgeführt • Monat 16: EDR (Endpoint Detection & Response) ausgerollt
	Mensch & Kultur	• Laufend: Quartalsweise Awareness-Schulungen (alle Mitarbeitenden, max. 15 Minuten) • Monat 12: Erste Phishing-Simulation, Ergebnis als Lernmoment (nicht als Sanktionsinstrument)
Phase 3: Konsolidierung & Zertifizierung (Monat 19–24) Budget: 15.000–30.000 €	Governance	• Internes ISMS-Audit (Monat 20) • Gap-Analyse zur ISO/IEC 27001:2022 Zertifizierungsreife. • Meilenstein Monat 24: Externes ISO 27001 Audit – Zertifizierung angestrebt.

4. Erwartete Wirkung & KPIs

4.1 KPI-Dashboard

Messung gemäß ISO/IEC 27004:2016 [17] und NIST SP 800-55 [18]:

KPI	Ausgangswert (geschätzt)	Zielwert	Zeithorizont
MTTD: Mean Time to Detect	Unbekannt / Tage	< 24 Stunden	Monat 18
MTTR (kritische Systeme) Mean Time to Respond	Unbekannt / Tage	< 4 Stunden	Monat 18
Patch-Compliance	< 50 % (geschätzt)	≥ 95 % innerhalb 30 Tage	Monat 12
Phishing-Klickrate	~25 % (KMU-Branchenschnitt) [2]	< 5 %	Monat 24
Backup-Recovery-Erfolgsrate	Ungetestet / unbekannt	100 % (quartalsweise validiert)	Monat 1
Kritische offene Findings (aus Risikoanalyse)	Unbekannt	= 0	Monat 12
Schulungsabschlussquote	0 %	≥ 90 % pro Jahr	Monat 6
Ungeplante Dienstleisterzugänge	Unbekannt	= 0	Monat 9

4.2 Mittelfristige Wirkung (12–24 Monate)

- Reduktion kritischer Schwachstellen um ≥ 80 %
- Recovery-Zeit: von unbekannt/improvisiert auf < 72 Stunden (NIS2-konform)
- Phishing-Klickrate: von ~25 % auf < 5 %
- NIS2-Compliance: erreicht
- Keine ungeplanten Remote-Zugänge mehr aktiv

4.3 Langfristige Wirkung (24–48 Monate)

- **ISO/IEC 27001:2022-Zertifizierung** als Nachweis gegenüber Kunden und Lieferanten
- **Sinkende Cyber-Versicherungsprämien** (zertifizierte ISMS werden von Versicherern besser bewertet)
- **Reduziertes Geschäftsführung-Haftungsrisiko** gemäß §43 GmbHG (Fahrlässigkeit bei Cyberschäden ist persönlich haftungsrelevant)
- Wettbewerbsvorteil: Kunden aus der Automobilindustrie und dem öffentlichen Sektor verlangen zunehmend ISMS-Nachweise in der Lieferkette

4.4 Return on Security Investment (ROSI)

Das Gordon-Loeb-Modell [19] empfiehlt einen optimalen Sicherheitsinvest von ca. **37 % des erwarteten Schadens**. Für die Maschinenbau Augsburg GmbH:

Parameter	Annahme	Grundlage
Durchschnittlicher Tageserlös	Unternehmensspezifisch (Platzhalter: 50.000 €/Tag)	Unternehmensangabe erforderlich
Produktionsstillstand Ransomware	21 Tage	IBM Security, 2025 [2]
Erwarteter Schadensfall (Ransomware)	1.050.000 € (Beispiel)	21 × 50.000 €
Empfohlener ISMS-Invest (37 % nach Gordon-Loeb)	388.500 €	[19]
Tatsächliches ISMS-Invest (dieses Konzept)	80.000–150.000 €	Deutlich unter optimaler Schwelle

Das vorgeschlagene Budget liegt signifikant unterhalb des Gordon-Loeb-Optimums – das Konzept ist somit **konservativ und wirtschaftlich vertretbar**. Allein die Vermeidung eines einzigen Ransomware-Vorfalls rechtfertigt die gesamte ISMS-Investition mehrfach.

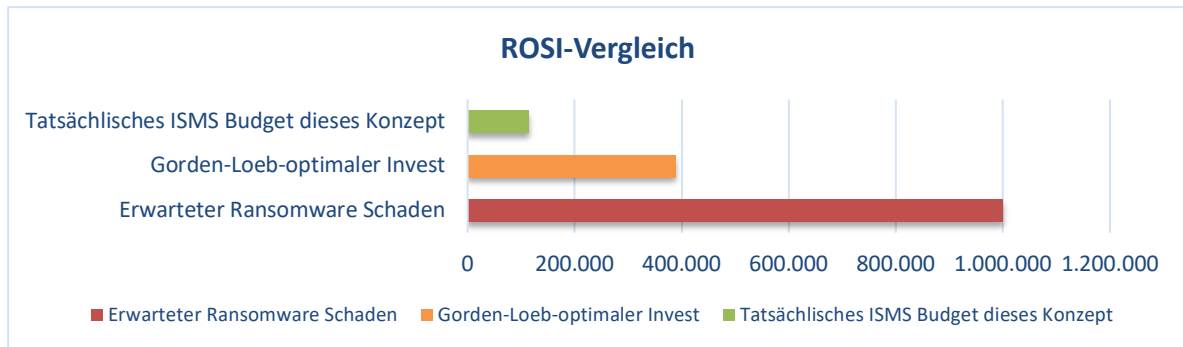


Figure 2: Das vorgeschlagene ISMS-Budget entspricht ca. 11 % des erwarteten Ransomware-Schadens.

5. Ressourcenbedarf und Budge

Ressource	Phase 1 (M 1–6)	Phase 2 (M 7–18)	Phase 3 (M 19–24)
ISB	Extern 50 %	Intern/Extern Mix	Intern
IT-Zusatzlast	+20 %	+30 %	Normalbetrieb
Führungszeit (GF)	3–4 h/Monat	2–3 h/Monat	1–2 h/Monat
Betriebsrat	3–4 Termine	Quartalsweise	Jahresbericht
Budget	25.000–40.000 €	40.000–80.000 €	15.000–30.000 €
Gesambudget	-		80.000–150.000 €

Hinweis zur IT-Kapazität: Die aktuelle 3-köpfige IT-Abteilung ist im operativen Dauerstress. Der ISB entlastet die IT bei strategischen ISMS-Aufgaben. Dennoch muss in Phase 2 temporäre externe IT-Unterstützung für OT-Monitoring und PAM-Implementierung eingeplant werden (in Budget Phase 2 enthalten).

Förderhinweis: Das BSI fördert KMU-Cybersicherheitsmaßnahmen über das Programm „Cybersicherheitsstrategie für Deutschland“ [20]. Zusätzlich bieten Bayern Innovativ und die IHK Schwaben Beratungszuschüsse für KMU.

6. Schlussbetrachtung

Die Maschinenbau Augsburg GmbH hat die Wahl zwischen zwei Szenarien:

1. **Szenario A – Reaktiv:** Das Unternehmen wartet, bis ein Vorfall eintritt. Die regionalen Beispiele – von den Wertachkliniken Bobingen (September 2024) über Brockhaus Fertigungstechnik (Januar 2026) bis zum Fertigungsunternehmen in Bayerisch-Schwaben (Juni 2025) – zeigen, dass dieser Moment kommen kann: 21 Tage Produktionsstillstand, Datenverlust, Reputationsschaden, Kundenabwanderung, GF-Haftung.
2. **Szenario B – Systematisch:** Das Unternehmen investiert jetzt 80.000–150.000 € in ein akzeptanzorientiertes ISMS, das Technologie, Governance und Kultur gleichrangig adressiert. Das Ergebnis nach 24 Monaten: ein messbares Sicherheitsniveau (Stufe 3), eine motivierte Belegschaft, die Sicherheit als Qualitätsmerkmal – nicht als Hemmnis – versteht, und eine ISO/IEC 27001-Zertifizierung als Wettbewerbsvorteil.

Der entscheidende Unterschied dieses Konzepts gegenüber klassischen IT-Projekten liegt in der gleichrangigen Behandlung von **Technologie, Governance und Mensch**. Sicherheit ist keine Software-Frage, sie ist eine Führungs- und Kulturaufgabe.

Wir empfehlen, mit der Benennung des ISB und dem ersten GF-Workshop im kommenden Monat zu beginnen.

Quellenverzeichnis

- [1] Bitkom e.V., „Wirtschaftsschutz 2025: Gesamtschaden durch Cyberkriminalität in Deutschland," Bitkom e.V., Berlin, Deutschland, Technischer Bericht, 2025.
- [2] IBM Corporation, „IBM Security X-Force Threat Intelligence Index 2025," IBM Corporation, Cambridge, MA, USA, Technischer Bericht, 2025.
- [3] IBM Corporation, „IBM X-Force Threat Intelligence Index 2025: Manufacturing Sector Analysis," IBM Corporation, Cambridge, MA, USA, Technischer Bericht, 2025.
- [4] IHK München und Oberbayern, „Cybersicherheitsreport Bayern 2026: Betroffenheit bayerischer Betriebe," IHK München und Oberbayern, München, Deutschland, Bericht, 2026.
- [5] International Organization for Standardization / International Electrotechnical Commission, „Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements," ISO/IEC 27001:2022, ISO/IEC, Genf, Schweiz, 2022.
- [6] J. W. Brehm, A Theory of Psychological Reactance. New York, NY, USA: Academic Press, 1966.
- [7] International Electrotechnical Commission, „Security for Industrial Automation and Control Systems – Part 3-3: System Security Requirements and Security Levels," IEC 62443-3-3:2013, IEC, Genf, Schweiz, 2013.
- [8] International Organization for Standardization / International Electrotechnical Commission, „Information Technology – Security Techniques – Information Security Incident Management," ISO/IEC 27035:2016, ISO/IEC, Genf, Schweiz, 2016.
- [9] J. P. Kotter, Leading Change. Boston, MA, USA: Harvard Business School Press, 1996.
- [10] R. von Solms und J. van Niekerk, „From information security to cyber security," Computers & Security, Bd. 38, S. 97–102, Okt. 2013, doi: 10.1016/j.cose.2013.04.004.
- [11] L. Kohnfelder und P. Garg, „The Threats to Our Products," Microsoft Interface, Microsoft Corporation, Redmond, WA, USA, 1999. [Online]. Verfügbar: <https://adam.shostack.org/microsoft/The-Threats-To-Our-Products.docx>
- [12] R. B. Cialdini, Influence: The Psychology of Persuasion, überarbeitete Aufl. New York, NY, USA: Harper Business, 2007.
- [13] J. Reason, Managing the Risks of Organizational Accidents. Aldershot, UK: Ashgate, 1997.
- [14] K. Lewin, „Frontiers in group dynamics: Concept, method and reality in social science; social equilibria and social change," Human Relations, Bd. 1, Nr. 1, S. 5–41, 1947, doi: 10.1177/001872674700100103.
- [15] J. M. Hiatt, ADKAR: A Model for Change in Business, Government and our Community. Loveland, CO, USA: Prosci Learning Center Publications, 2006.
- [16] C. O. Scharmer, Theory U: Leading from the Future as It Emerges, 2. Aufl. San Francisco, CA, USA: Berrett-Koehler, 2016.
- [17] International Organization for Standardization / International Electrotechnical Commission, „Information Technology – Security Techniques – Information Security Management – Monitoring, Measurement, Analysis and Evaluation," ISO/IEC 27004:2016, ISO/IEC, Genf, Schweiz, 2016.
- [18] National Institute of Standards and Technology, „Performance Measurement Guide for Information Security," NIST SP 800-55 Rev. 1, NIST, Gaithersburg, MD, USA, Jul. 2008.
- [19] L. A. Gordon und M. P. Loeb, „The economics of information security investment," ACM Transactions on Information and System Security, Bd. 5, Nr. 4, S. 438–457, Nov. 2002, doi: 10.1145/581271.581274.
- [20] Bundesamt für Sicherheit in der Informationstechnik (BSI), „BSI für Unternehmen und Organisationen: Förderprogramme und Unterstützungsangebote," BSI, Bonn, Deutschland, 2025. [Online]. Verfügbar: <https://www.bsi.bund.de>